

DROS 4-Layer Defense-in-Depth Architecture for Autonomous AI Workloads

A Complete Security & Execution Governance Paradigm for the Agentic Web Era

Chun-Cheng (Jimmy) Chen
Top-Celestial Company Ltd.
Taipei, Taiwan R.O.C.
jimmychen@dr-os.io

Abstract—In 2026, autonomous AI agents capable of multi-step tool execution are deployed across critical enterprise domains—financial compliance, supply chain routing, and infrastructure management. However, existing security primitives face severe architectural boundaries: application-level prompt firewalls (e.g., NVIDIA NeMo Guardrails) remain fundamentally probabilistic and vulnerable to Indirect Prompt Injection (IPI), while kernel-level OS sandboxes (e.g., eBPF, Seccomp) suffer from execution “context-blindness,” unable to map user-space agent roles to low-level process streams. To bridge this “Attribution Gap,” we present the DROS 4-Layer Defense-in-Depth Architecture, a zero-trust runtime execution control plane purpose-built for the Agentic Web era. The architecture decouples Control Plane Provisioning (via OpenAI Terraform Provider & OpenShip) from Runtime Physical Execution Defense. By enforcing immutable $O(1)$ capability bitmaps at the binary C-ABI / FFI boundary, DROS achieves sub-microsecond decision latency (26.21 μ s median, <500 ns panic latency). Coupled with a 3-tier PKI Certificate Authority (Root CA $\rightarrow$ AIA $\rightarrow$ BEC Leaf Token) issuing signed `DrosIdentityTokens` (DIT), DROS provides court-admissible, non-repudiable audit logs signed via Ed25519 for regulatory compliance (EU AI Act Sec. 50). Benchmark evaluations demonstrate 100% containment against zero-day prompt injection, Goal Hijacking, and cross-enterprise supply chain attacks.

Index Terms—AI Agent Security, Runtime Execution Governance, C-ABI Boundary Enforcement, Zero Trust Architecture, Public Key Infrastructure (PKI), Indirect Prompt Injection (IPI), EU AI Act Compliance.

I. INTRODUCTION

The rapid transition from conversational passive LLMs to autonomous, tool-calling AI agents has fundamentally altered the enterprise threat surface. Modern autonomous agents are entrusted with API keys, OAuth grants, and transactional database permissions. Consequently, when an agent is compromised, the threat actor operates from *within* legitimate security boundaries.

A. The Failure of Identity & Network-Centric Defenses

Traditional Web Application Firewalls (WAF), Endpoint Detection and Response (EDR), and Identity & Access Management (IAM) systems operate on the assumption that attackers do not possess valid credentials. In the Agentic Web era, a hijacked agent *is* a credentialed actor. WAFs view high-privilege API calls as authorized traffic, while EDRs see

generic OS runtimes (e.g., `python.exe` or `node`) executing valid system calls.

B. The Semantic-Kernel Paradox

As highlighted in recent systems literature (e.g., AgentSight, IEEE S&P 2026), AI agent security suffers from a fundamental paradox:

- 1) **Semantic Firewalls (High Semantics, Zero Determinism):** Prompt filters inspect high-level natural language intent but offer zero mathematical guarantees against adversarial obfuscation or multi-turn context poisoning.
- 2) **Kernel Sandboxes (High Determinism, Zero Semantics):** OS-level mechanisms like eBPF or Seccomp enforce strict binary syscall rules but lack user-space context. They cannot discern whether a `sys_connect` to an internal database was initiated by a legitimate Finance Agent or a hijacked Support Agent running inside the same process worker.

1. Control Plane & GitOps Provisioning (Policy-as-Code)
 - OpenAI Terraform Provider $\rightarrow$ Provision Projects
 - OpenShip Engine $\rightarrow$ Orchestrate Multi-tenant
2. DROS Runtime Execution Defense (L4 - C-ABI Boundary)
 - 3-Tier PKI Certificate Chain $\rightarrow$ `DrosIdentityTokens`
 - DROS GuardVM (PEP/PDP) $\rightarrow$ Sub-microsecond

II. THREAT MODEL: AGENTIC ATTACK VECTORS (AAV-2026)

We define runtime attack vectors targeting autonomous AI agents as **Agentic Attack Vectors (AAV-2026)**:

III. THE DROS 4-LAYER DEFENSE-IN-DEPTH ARCHITECTURE

DROS establishes a 4-layer defense-in-depth model separating probabilistic filters from deterministic execution gates:

- | | |
|----------------------------------|------------------|
| L1: Detective Intelligence Layer | Semantic Prompt |
| L2: Zero Trust Mesh & PKI Layer | 3-Tier CA (Root) |

TABLE I
AGENTIC ATTACK VECTORS TAXONOMY

Attack Vector	MITRE ATLAS	Mechanism & Impact
Indirect Prompt Injection (IPI)	AML.T0051	Adversaries embed malicious prompt payloads into untrusted external data, hijacking tool-calling flows.
Goal Hijacking	AML.T0054	Context window poisoning alters long-term objectives, causing agents to execute unauthorized multi-step action chains.
Privileged Function Escalation	AML.T0053	Compromised agents use valid OAuth tokens to invoke high-privilege endpoints beyond role scope.
Supply Chain Contagion	AML.T0010	Poisoned external repositories compromise data-fetching agents, which then pivot to attack internal assets.

If the bit is 0, the execution physically fails at the C-ABI binary boundary within **<500 ns panic latency**.

IV. FEDERATED B2B MULTI-ENTERPRISE SUPPLY CHAIN DEFENSE

When autonomous agents interact across enterprise boundaries (e.g., Corp-Alpha / OpenAI Workload fetching data from Corp-Beta / Hugging Face Repository), DROS transforms L2 into a Cross-Domain Identity Fingerprinting Gate.

V. EXPERIMENTAL EVALUATION & BENCHMARK RESULTS

A. Open-Source Proving Ground

All empirical evaluations were executed inside the **DROS-VEP Lite** open-source containerized environment. Test harness scripts are open-sourced at github.com/Top-Celestial-Company-Ltd/DROS-VEP-lite.

B. Comparative Counterfactual Benchmark

TABLE II
COUNTERFACTUAL BENCHMARK RESULTS (CONTROL VS. PROTECTED)

Benchmark Scenario	Control (No Guard)	Protected (Guard L4)	Latency
ATS-001 (EP1 Ex-fil)	100% Leaked	100% Intercepted	25.8 μ s
ATS-002 (EP2 Secret)	100% Leaked	100% Intercepted	26.1 μ s
ATS-003 (EP3 Deploy)	100% Pushed	100% Intercepted	25.5 μ s
ATS-004 (EP4 Supply)	100% Hijacked	100% Intercepted	26.4 μ s

C. Micro-Benchmark Telemetry Statistics (24-Hour Soak Test)

TABLE III
24-HOUR CONTINUOUS SOAK TEST TELEMETRY

Evaluation Metric	Empirical Value	Notes
Total Evaluation Workload	160,611 Requests	Continuous 24.0h
Policy Decision Latency (P50)	26.21 μ s	$\pm 0.34 \mu$ s
P99 Policy Latency	242.69 μ s	Concurrency Spike
C-ABI Physical Panic Latency	< 500 ns	Binary Gate
SPEC CPU2017 Overhead	< 1.8%	Low Context Switch
Deterministic Containment	100% (0 Leak)	137,751 Intercepts
24-Hour Memory Leak	0 Bytes	Zero Heap Alloc

VI. RELATED WORK

Our work builds upon and extends recent security domains: System Call Interception (eBPF AgentSight), LLM Agent Security (OWASP Top 10 for Agentic Applications), Zero Trust Architecture (NIST SP 800-207), and Non-Repudiation Audit Substrates (EU AI Act Sec. 50).

L3: Task Orchestration Layer

L4: C-ABI Physical Enforcement <500ns 0 (1) Binary Panic Gate

A. L1: Detective Intelligence Layer

L1 applies semantic analysis to sanitize natural language inputs, intercepting known prompt injection patterns and jail-break templates. Because L1 is probabilistic, it serves as an early filter rather than the final line of defense.

B. L2: Zero Trust Mesh & PKI Identity Layer

To eliminate “context-blindness,” L2 introduces a 3-tier Public Key Infrastructure:

- **Root CA:** Enterprise Root (DROS-ROOT-CA-2026).
- **AIA Intermediate:** Authority Information Access issuer.
- **BEC Leaf Certificate:** By-Execution Certificate cryptographically binding the agent’s identity, role, and authorized skill maps.

Every tool call carries a signed **DrosIdentityToken (DIT)**. GuardVM verifies the ECDSA/Ed25519 signature before inspecting permissions.

C. L3: Task Orchestration Layer

L3 enforces Attribute-Based Access Control (ABAC) across multi-agent swarms using `agent_manifest.yaml`. It isolates blast radiuses by restricting inter-agent communication channels to pre-approved graph topologies.

D. L4: C-ABI Physical Enforcement Layer

L4 is the core innovation of DROS. Permissions are pre-compiled into immutable numeric Bitmaps at initialization. When a tool call is executed, GuardVM performs an $O(1)$ bitwise AND operation:

Decision = Capability_Bitmap[Role_ID] & Requested_Tool_Bit (1)

VII. CONCLUSION & FUTURE WORK

This paper presents the DROS 4-Layer Defense-in-Depth Architecture, establishing a deterministic runtime control plane combining 3-tier PKI identity attestations with sub-microsecond C-ABI binary boundary enforcement ($<500\text{ns}$ panic latency, $26.21\mu\text{s}$ median evaluation). Empirical 24-hour benchmark evaluations demonstrate 100% deterministic interception without modifying underlying LLM architectures.

ACKNOWLEDGMENT AND AI COLLABORATION DISCLOSURE

The original security models, C-ABI boundary interception paradigms, and patent-pending claims (U.S. PPA No. 64/111,973) were conceived, developed, and validated solely by Chun-Cheng (Jimmy) Chen. Generative AI tools were utilized strictly as formatting and linguistic assistants.

REFERENCES

- [1] NIST SP 800-207, “Zero Trust Architecture,” NIST, 2020.
- [2] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications v1.1,” 2023.
- [3] MITRE Corporation, “MITRE ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems,” 2024.
- [4] X. Zhang et al., “AgentSight: eBPF-Powered Tracing and Context Correlation for Autonomous LLM Agents,” arXiv preprint arXiv:2408.01234, 2024.
- [5] C. C. Chen, “Runtime Attribution Framework: An External C-ABI and PKI-Based Zero-Trust Infrastructure for Non-Repudiable Execution Governance in Multi-Agent Systems,” Zenodo, DOI: 10.5281/zenodo.20823163, 2026.
- [6] C. C. Chen, “DROS-PGM: Deterministic Kernel-Level Execution Control for Post-Compromise Security,” U.S. Patent Application No. 64/111,973, 2026.
- [7] European Parliament and Council, “Regulation (EU) 2024/1689 Laying Down Harmonised Rules on Artificial Intelligence (EU AI Act),” Official Journal of the EU, 2024.